

Harbor Ridge Bank Board Risk Packet

SYNTHETIC EXERCISE DATA - NOT A REAL BANK

Executive summary

A coordinated disruption could exceed service and data-integrity tolerances because identity, payments, telecommunications, and recovery have common-mode dependencies. This packet supports review; it does not make the board's decision.

Scenario

Geopolitical conflict drives ambiguous pre-positioning followed by identity, channel, payment, telecommunications, integrity, and recovery disruption.

Critical services

16 services are modeled from customer authentication through technology recovery.

Tier 0 methodology

Begin with critical services and tolerances; map dependencies; identify common-mode failure; apply explicit rules; require accountable human approval. Tier 0 is Harbor Ridge terminology, not a regulatory designation or a NIST CSF Implementation Tier.

Tier 0 concentration risks

Enterprise identity, Privileged-access management, Core banking, Payment processing, General ledger, Network management, Cloud tenant administration, Key and certificate management, Backup control plane, Recovery orchestration, Time synchronization, Authoritative DNS, Transaction reconciliation data.

Current preparedness

Synthetic baseline: partial immutable backup, manual payment, privileged access, and alternate communications capability; validation remains required.

Material control gaps

Recovery administration shares production identity; telecommunications and payment processors remain concentrated; recovery-point integrity validation is incomplete.

Exercise decisions

6 decisions recorded. Empty outcomes are not presented as performance results.

Impact-tolerance breaches

Calculated from elapsed disruption, backlog, and data uncertainty; none are asserted before exercise inputs exist.

Residual risk

Material residual risk remains until clean-room recovery, independent credentials, reconciliation, and substitution plans are demonstrated.

Investment alternatives

Prioritize independent clean-room recovery; phishing-resistant administrative authentication; immutable, integrity-validated backups; telecommunications diversity; and third-party exit testing.

Management recommendation

Fund a sequenced resilience program that first removes recovery common modes, then expands detection, redundancy, and repeatable validation.

Board decisions requested

Approve appetite statements, investment envelope, accountable owners, and quarterly evidence-based oversight.

Ninety-day actions

Inventory and approve Tier 0; freeze unmanaged privilege; test clean credentials; validate immutable copies; rehearse minimum viable payments and alternate communications.

One-year resilience roadmap

Quarter 1: control-plane isolation. Quarter 2: clean-room exercise. Quarter 3: processor and carrier substitution. Quarter 4: enterprise reconciliation and board tolerance test.

Metrics for board oversight

Tested Tier 0 recovery; phishing-resistant admin MFA; isolation from production identity; manual-procedure coverage; concentration; privilege-disable time; clean-room time; unreconciled transactions; tolerance-meeting exercises; telemetry; critical findings; backup immutability; recovery-point integrity validation.